# Asignación de controles para la administración de riesgos

Durante esta capacitación, aprendiste sobre los controles y sobre cómo implementarlos para administrar el riesgo y satisfacer las obligaciones de cumplimiento. En esta lectura, aprenderás más sobre cómo asignar controles y verás un ejemplo de un mapa de control.

## Introducción a la asignación de controles

La asignación de controles puede ayudarte a identificar brechas de control y superposiciones entre distintos controles. La asignación de controles es una parte importante de la administración de riesgos y del proceso de cumplimiento. Cuando se evalúan y asignan los controles, los equipos de riesgo pueden ayudar a ahorrar tanto tiempo como esfuerzo.

## Primeros pasos

Como profesional de seguridad, puede que tengas que crear un mapa de control. Los mapas de control son hojas de cálculo que identifican, documentan y evalúan los controles implementados dentro de la organización. Los mapas de control serán diferentes dependiendo de las necesidades organizacionales y empresariales.

Para crear un mapa de control, genera una hoja de cálculo en la cual se detallen tus controles y se recopile evidencia de tu entorno en la nube de que estos controles se implementaron.

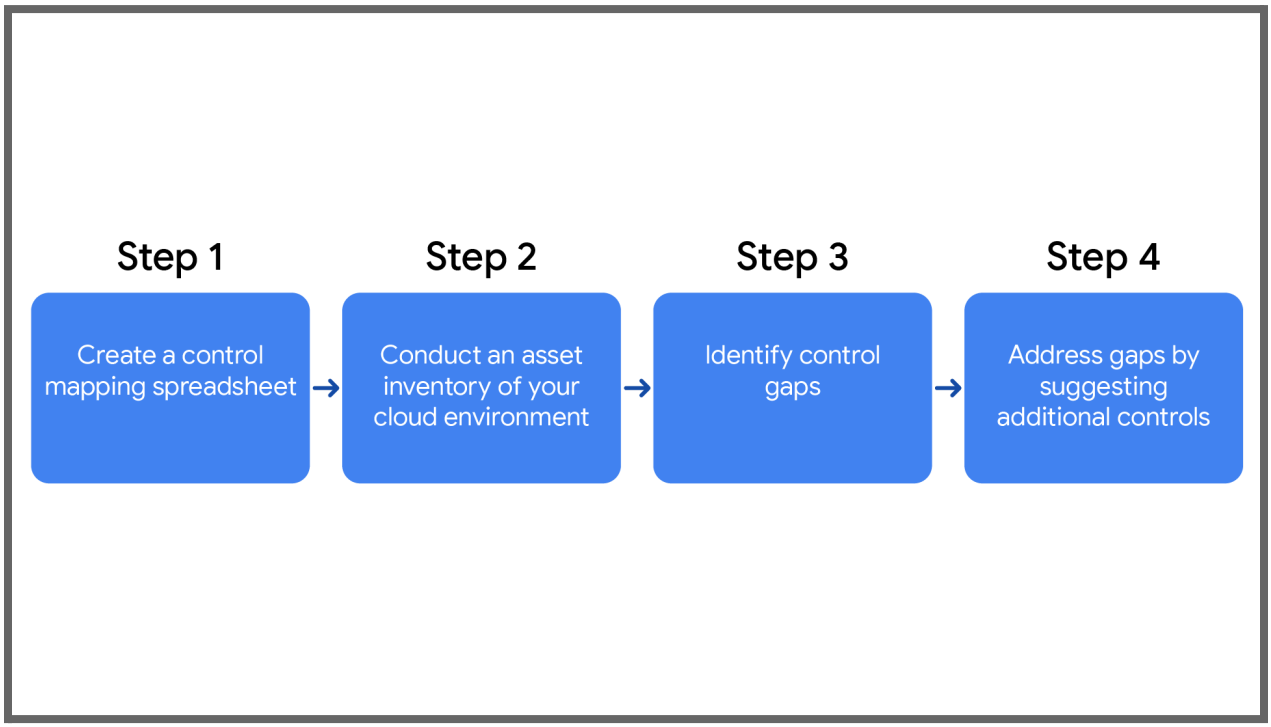
Tus hojas de cálculo de asignación de controles deberían incluir evidencia de los controles que implementa tu organización en conjuntos completos de frameworks, estándares y reglamentaciones de control. La recopilación de evidencia es el proceso por el cual se recolectan y documentan datos, registros y otros procesos de cumplimiento para demostrar que se cumple con las reglas, reglamentaciones y estándares. En el mapa de control, la evidencia es una explicación del control implementado y cómo este control cumple el requisito. Por ejemplo, si un framework de seguridad cibernética requiere autenticación de varios factores (MFA), querrás asegurarte de que tu organización utilice llaves de seguridad o cualquier otra herramienta que cumplan este requisito. Estas son algunas formas de recolectar evidencia: consultas a tu equipo, revisión de los mapas de control existentes, revisión de las políticas y los procedimientos de seguridad, informes de prueba y validación y evaluaciones de riesgo.

Las nuevas reglamentaciones suelen solicitar parámetros de configuración específicos de asignación de controles. Cuando se incorpora una nueva reglamentación, puedes comparar los nuevos requisitos de control con los controles que ya asignaste. También puedes anotar las diferencias entre las reglamentaciones nuevas y las existentes y, luego, agregar los controles que falten para cerrar las brechas, o bien quitar las asignaciones de controles obsoletos. Por ejemplo, si una nueva reglamentación solicita contraseñas nuevas para el personal cada 30 días en vez de cada 45 días, tu equipo de seguridad tendrá que implementar este control para poder cumplir con la nueva reglamentación y cerrar la brecha. Luego, puedes actualizar el mapa de control explicando cómo tu equipo cumplió con este requisito.

**Sugerencia profesional**: ¡No es necesario que empieces desde cero! Existen muchos otros recursos gratuitos disponibles. Puedes comenzar con los controles detallados de un mapa de control existente como el NIST SP 800-53 para generar tu asignación de controles en una hoja de cálculo de Google o Excel. También existen recursos útiles y sin costo que muestran tablas de correspondencia entre frameworks y reglamentaciones, incluidas las asignaciones del SP 800-53 del NIST con la norma ISO 27001 y del SP 800-53 del NIST con el CSF 1.1 del NIST.

Sigue estos pasos para crear un mapa de control y los controles del mapa:

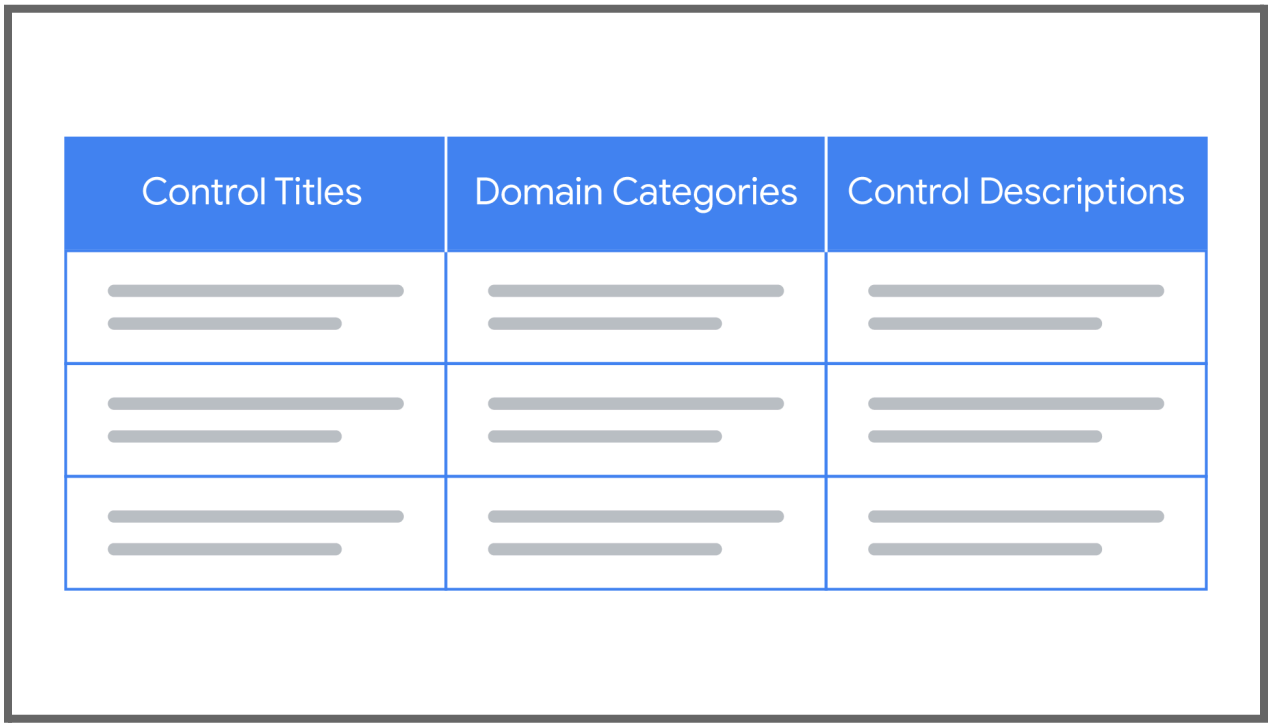
1. Crea una hoja de cálculo de asignación de controles.
2. Haz un inventario de los recursos de tu entorno en la nube.
3. Identifica las brechas de control.
4. Aborda las brechas proponiendo controles adicionales.



## Crea una hoja de cálculo de asignación de controles

A continuación, se enumeran de forma más detallada los pasos para crear y registrar evidencia en tu mapa de control.

Primero, crea una hoja de cálculo que incluya los títulos de los controles de seguridad, las categorías de los dominios y las descripciones para identificar los controles relacionados. Este gráfico es un ejemplo de una hoja de cálculo que se diseñó para asignar controles. Recuerda que puedes consultar recursos como el catálogo de controles SP 800-53 del NIST, que te pueden servir como ayuda para empezar.




## Haz un inventario de los recursos

Luego,haz un inventario de todos los recursos cibernéticos y virtuales del entorno en la nube de tu organización. El Google Cloud Asset Inventory puede ser una herramienta útil para hacer un inventario. Puedes registrar el inventario en una hoja de cálculo separada. Este inventario también se puede utilizar para determinar cuáles controles son los mejores para proteger tus recursos y mantener el cumplimiento.

## Asigna tus controles a un framework

Luego, evalúa tus controles actuales y asígnalos a los requisitos de tu organización o del framework. El documento Matriz de responsabilidad compartida del PCI DSS presenta una guía

de cumplimiento para cuatro categorías de producto que son centrales en el cumplimiento de las PCI DSS®. En estas categorías se incluyen: Compute, Herramientas de redes, Storage y Seguridad e identidad. Este documento desglosa la división de responsabilidades entre el proveedor de servicios en la nube y el cliente o usuario. Este tipo de documentos puede ayudarte a crear y organizar tus mapas de control. Recuerda que las obligaciones de cumplimiento pueden diferir según la organización, la industria y la ubicación.

## Identifica y aborda las brechas

Por último, analiza tu mapa de control para identificar brechas que deben abordarse. Para hacer esto, revisa los requisitos de control de los frameworks, las reglamentaciones y las políticas de la organización que incluiste en tu mapa para identificar cuáles no se cumplen. Una vez que identifiques los controles que falten, podrás abordar estas brechas proponiendo controles adicionales a tu equipo. Luego de que tu organización implemente estos controles, podrás agregar la evidencia a tu mapa de control para explicar cómo se cerró esa brecha con los controles adicionales.

## Conclusiones principales

Implementar controles para satisfacer las necesidades organizacionales y de cumplimiento puede ser una tarea difícil. Sin embargo, asignar controles te ahorra tiempo y esfuerzo, y ayudará a que tu organización mantenga una postura de seguridad fuerte y que cumpla con los requisitos.

Luego de asignar los controles y de identificar las brechas, puedes elegir controles específicos o cualquier otra solución para cerrar las brechas que identificaste. Esto te ayudará a reducir el riesgo y a satisfacer las obligaciones de cumplimiento.

## Recursos para obtener más información

Consulta el siguiente recurso para obtener más información:

- Ejemplo de una hoja de cálculo SP 800-53 del NIST